



CYBER SECURITY PRACTICAL GUIDE

NAME: Chandana Somanath Khatavakar

File Uploading Vulnerability

File upload vulnerabilities occur when an application improperly handles files uploaded by users, potentially allowing attackers to upload malicious files that can compromise the system. Here's how to identify and exploit file upload vulnerabilities using OWASP guidelines and Burp Suite:

1. Understanding File Upload Vulnerabilities

- **Unrestricted File Upload:** Applications that allow users to upload files without sufficient validation might enable attackers to upload malicious files (e.g., web shells or scripts) to the server, gaining control or leaking sensitive data.
- **Content-Type Bypass:** Attackers may bypass Content-Type restrictions to upload executable files.
- **File Extension and MIME Type Checks:** If applications only validate file extensions or MIME types, attackers can rename malicious files to accepted extensions (e.g., .jpeg instead of .php).

2. Using OWASP Testing Guide

- **OWASP File Upload Security Testing:** OWASP's testing guide provides best practices, including ensuring the uploaded files:
 - Are validated for both filename extensions and content.
 - Have strict limitations on executable file types.
 - Are uploaded to non-executable directories (to prevent server execution).
 - Are virus-scanned.

3. Testing File Upload Vulnerabilities with Burp Suite

Step 1: Intercept File Upload with Burp Suite

- Open Burp Suite and intercept the file upload request.
- Use **Burp Repeater** to modify the upload parameters and test various payloads, file extensions.

Step 2: Modify Content-Type Headers

- In the intercepted request, modify the Content-Type header to a non-standard MIME type (e.g., application/octet-stream), or change it to mimic an allowed file type, like image/jpeg.
- Test if the server accepts the file despite the modified headers.

Step 3: Bypass File Extension Checks

- Attempt to upload a malicious file (e.g., shell.php) with a renamed extension (e.g., shell.php.jpg) or using a double extension (e.g., shell.jpeg.php).
- If successful, this may indicate poor extension filtering on the server.

Step 4: Verify File Execution

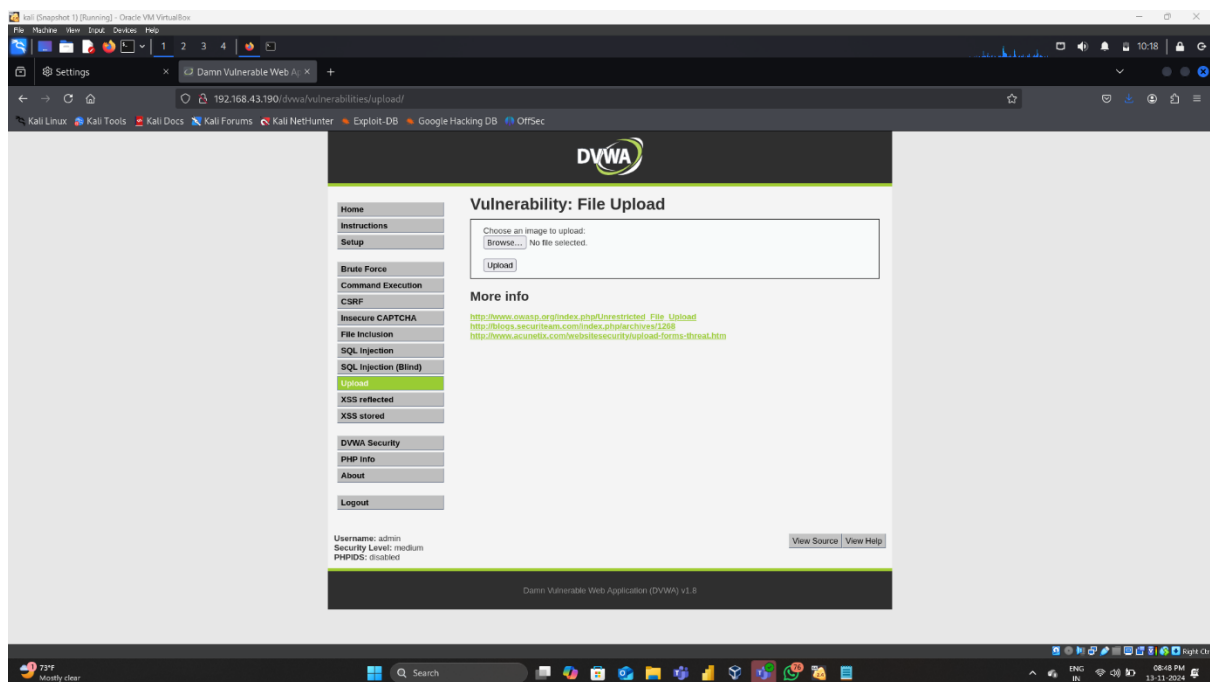
- After uploading the file, access its URL or location on the server.
- If the file executes (e.g., a .php file runs as code), this indicates a successful file upload vulnerability.

4. Mitigations and Best Practices

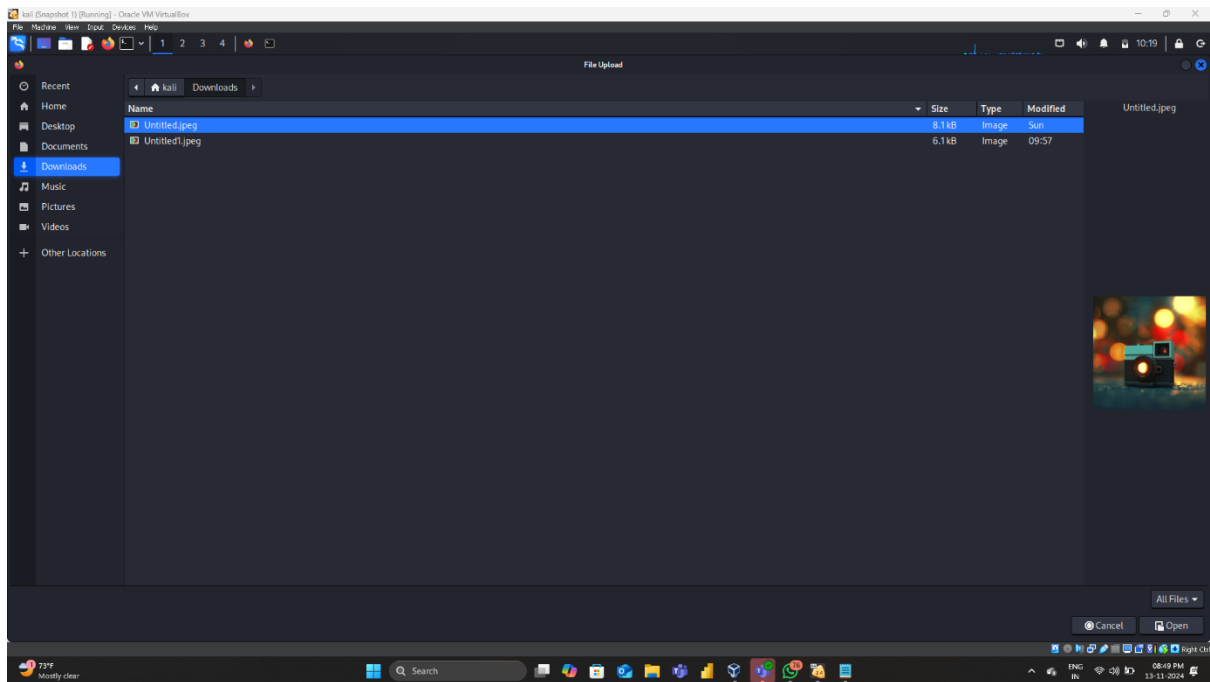
- **Server-Side Validation:** Implement strict validation on the server side, restricting upload file types, file sizes, and paths.
- **Store Files in Non-Executable Directories:** Ensure uploaded files are stored in a directory with no execute permissions to prevent web shells.
- **Use Virus Scanning:** Employ antivirus and malware scanning for uploaded files.
- **Limit File Types:** Restrict file types to safe formats (e.g., .jpg, .png) and reject executable formats.

PROCEDURES

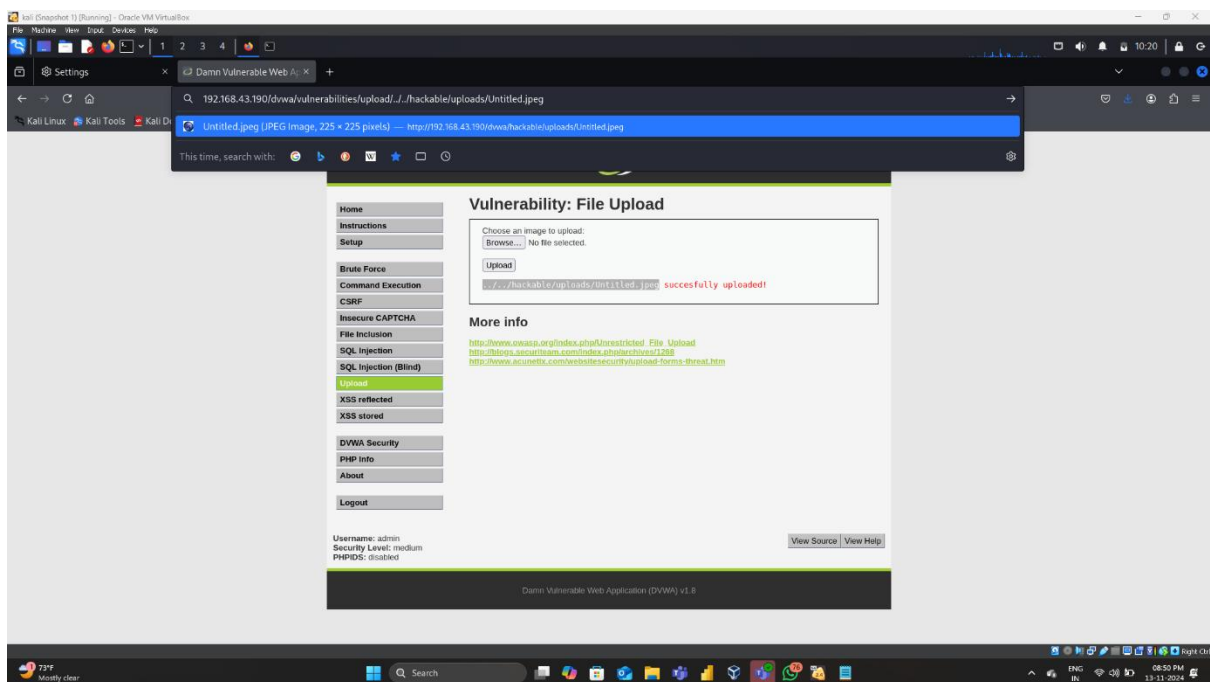
1. Go to OWASP machine and go to upload.



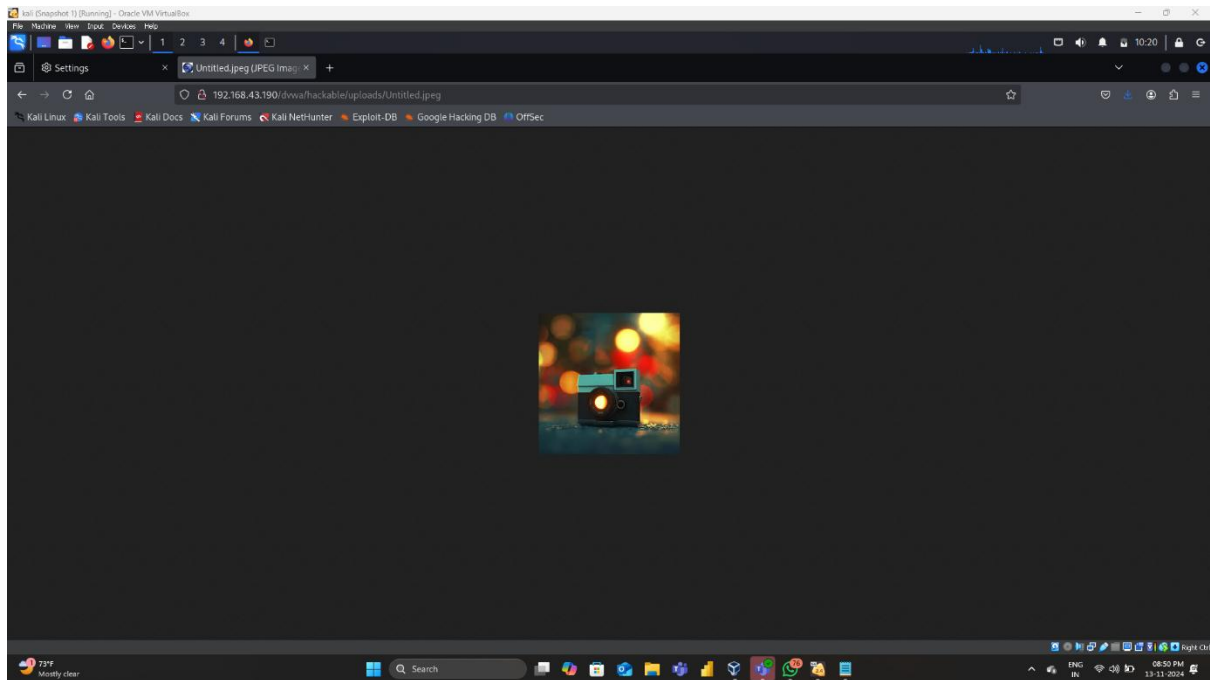
2. Click on Browse and upload the image (jpeg)



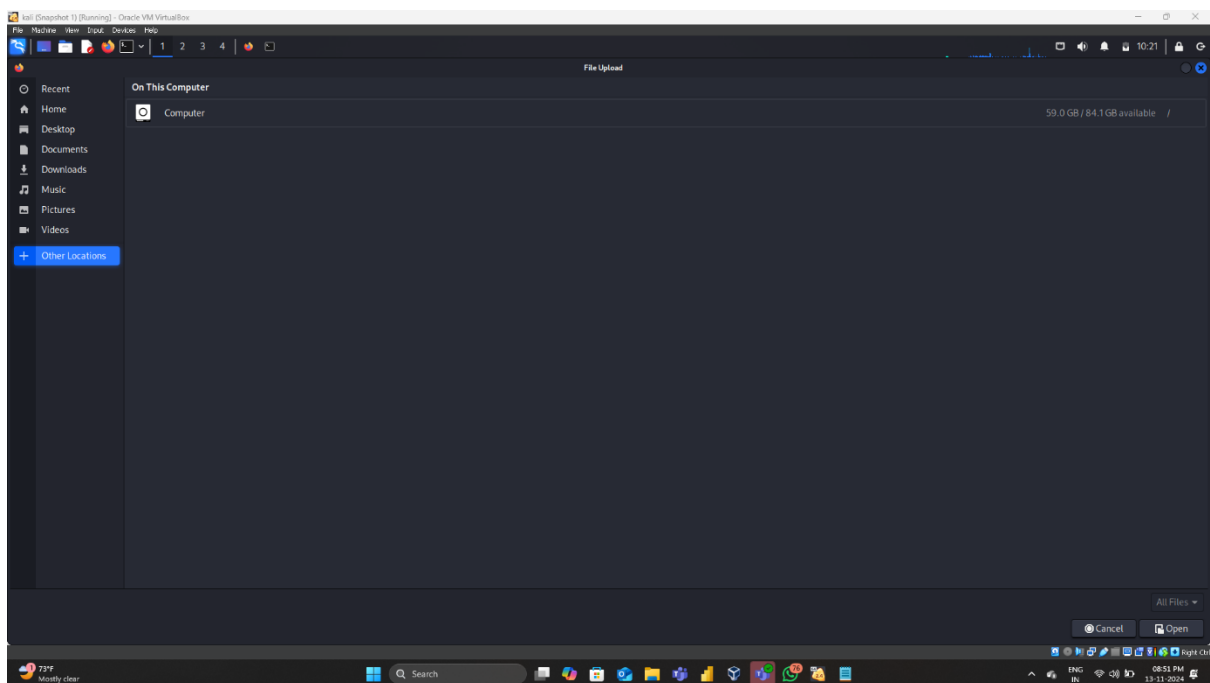
3. copy that line up to jpeg and paste it in url (note: remove #) click on enter



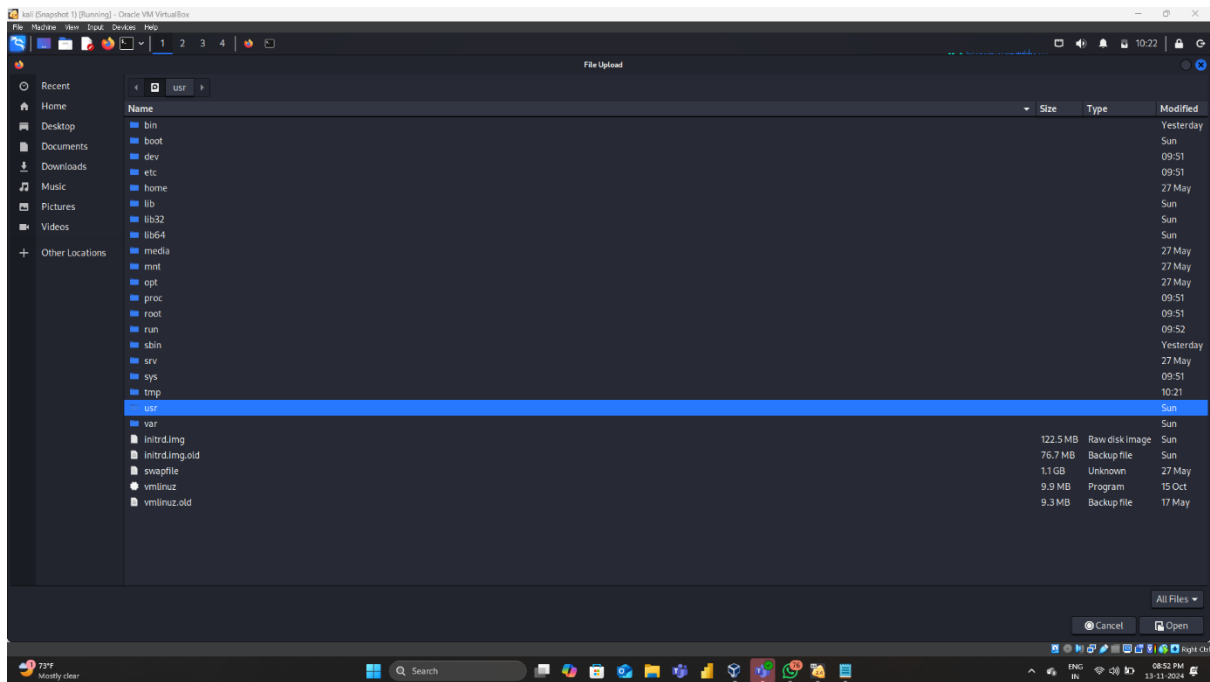
4. the below picture will come over there



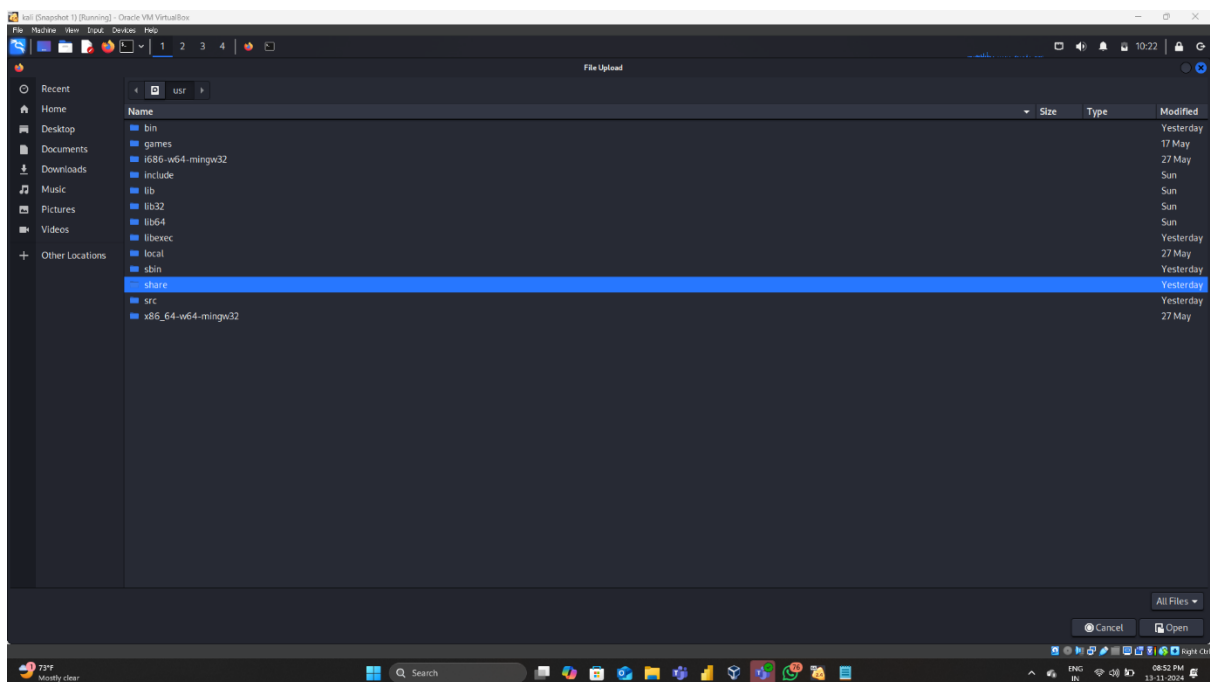
5. Go to other location



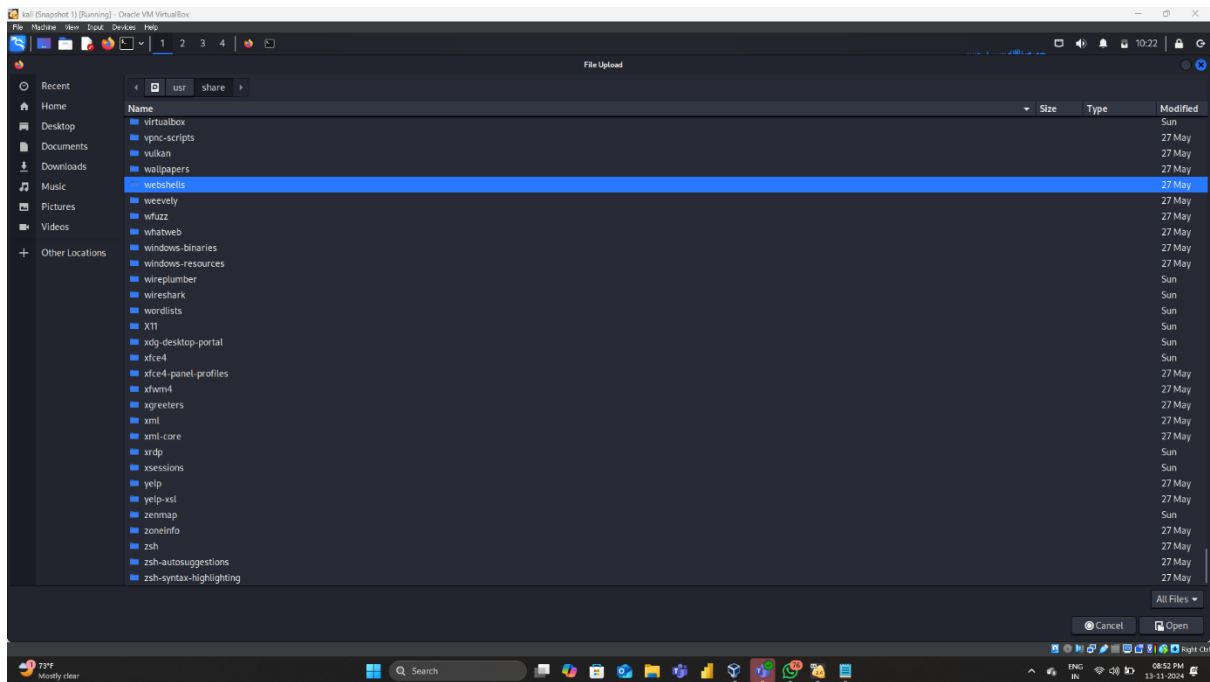
6. Go to usr



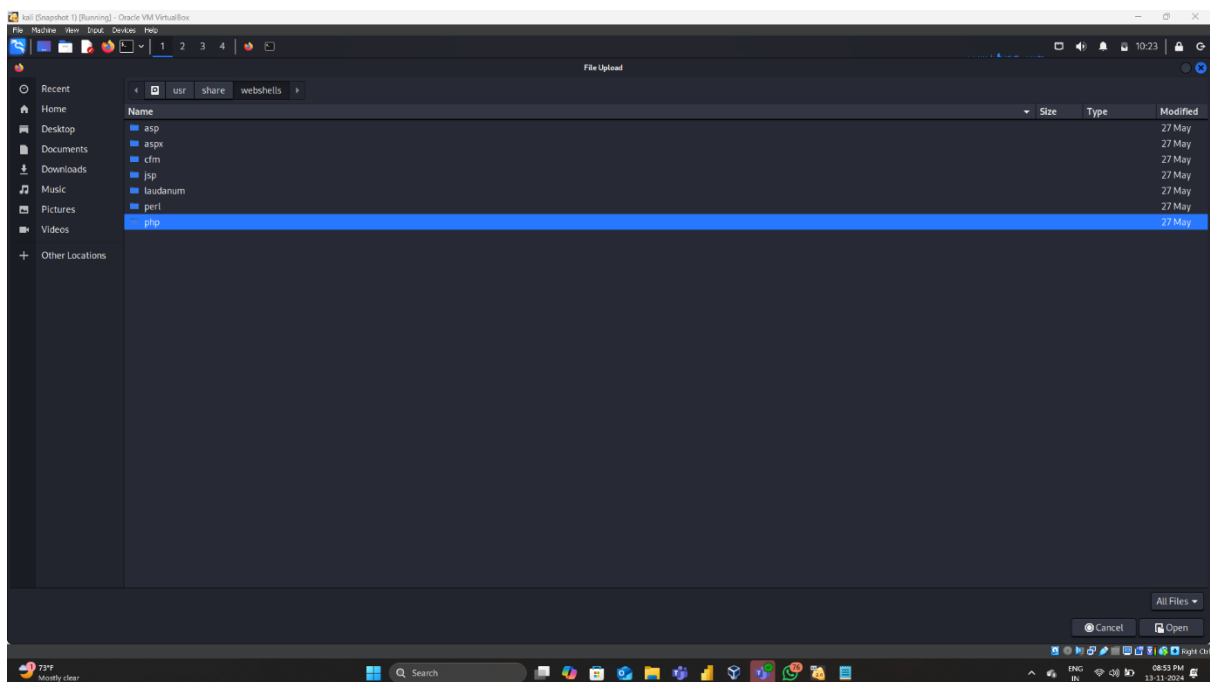
7. Go to share



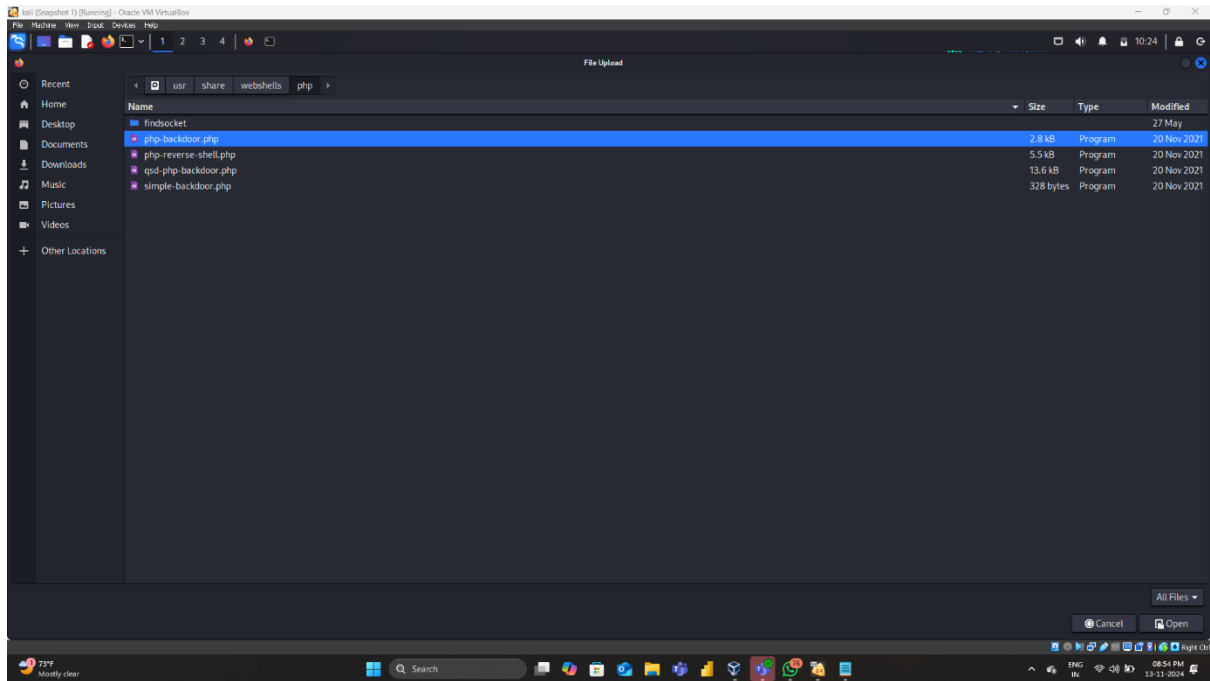
8. Go to webshells



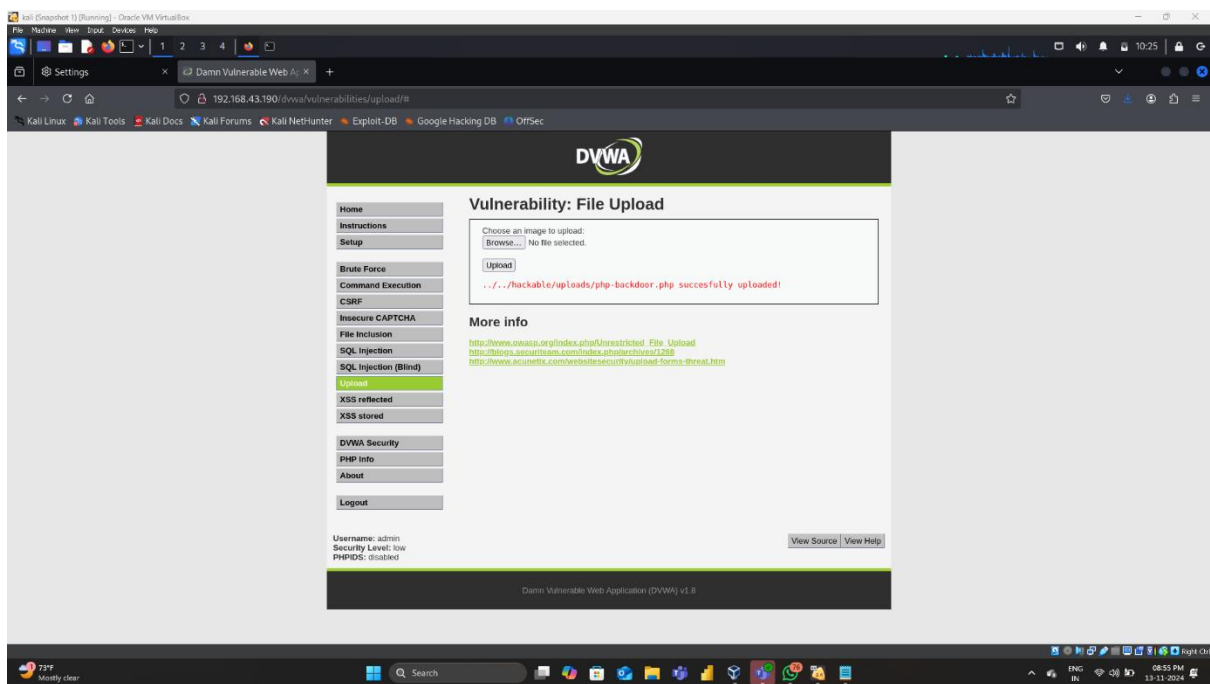
9. Go to php



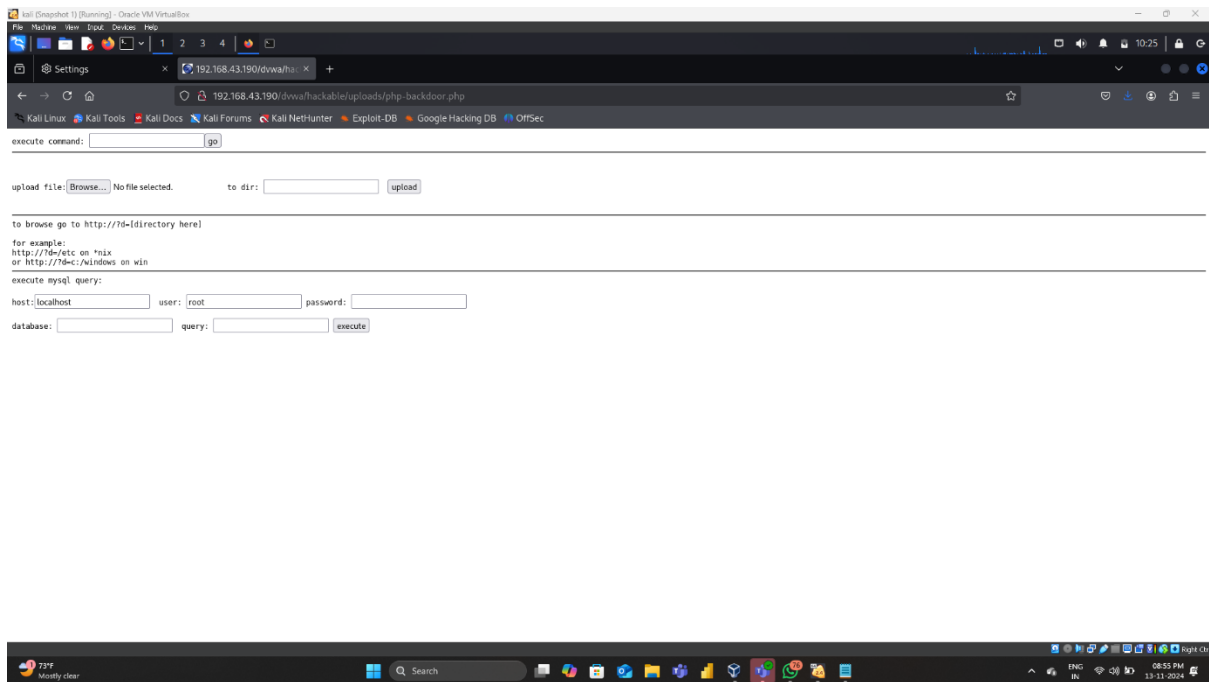
10. click on php-backdore.php



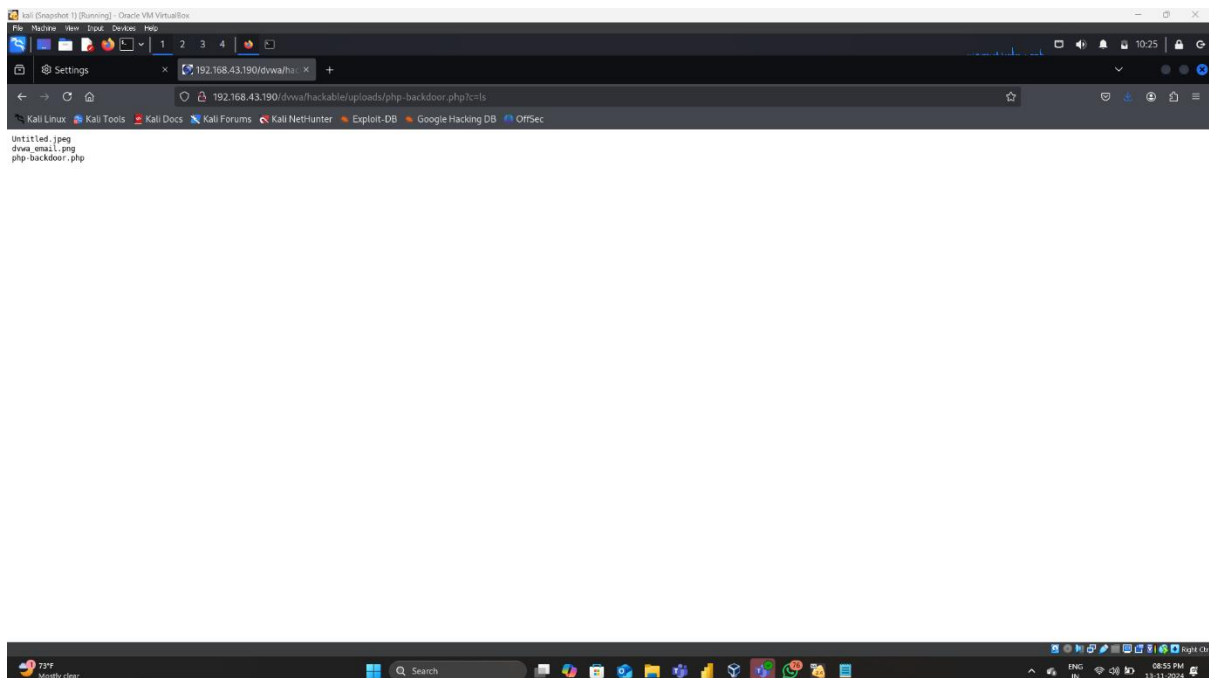
11. Upload it



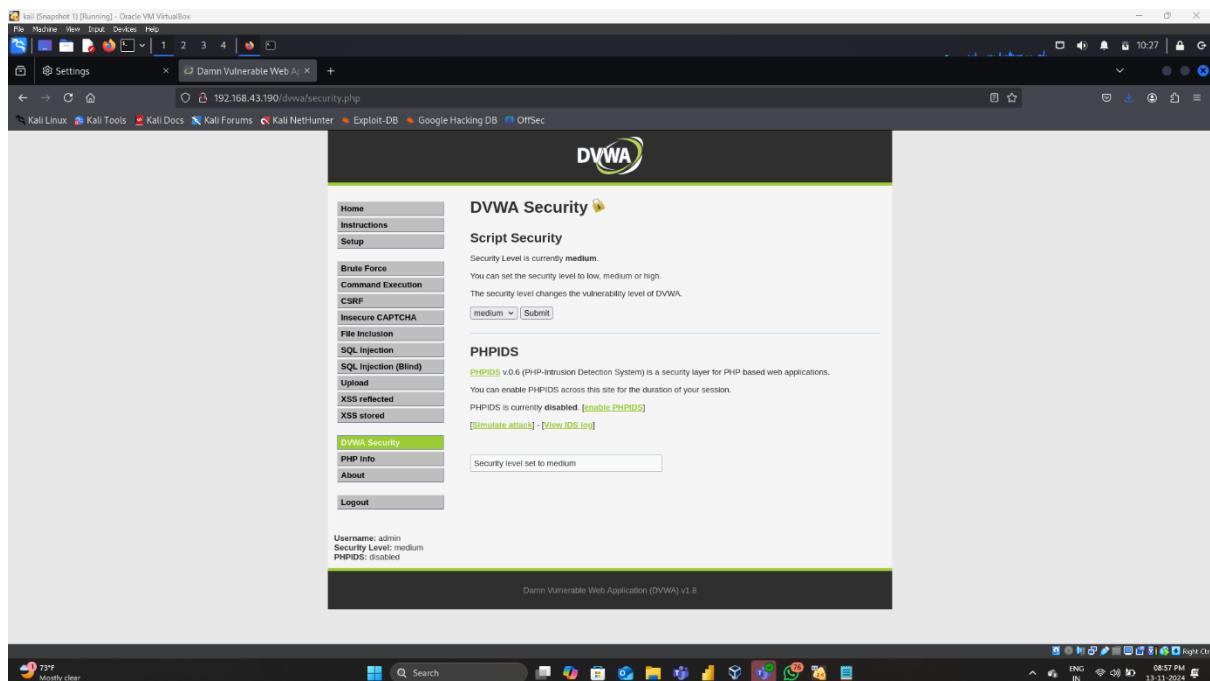
12. copy that line up to .php and paste it in url (note remove #) click on enter



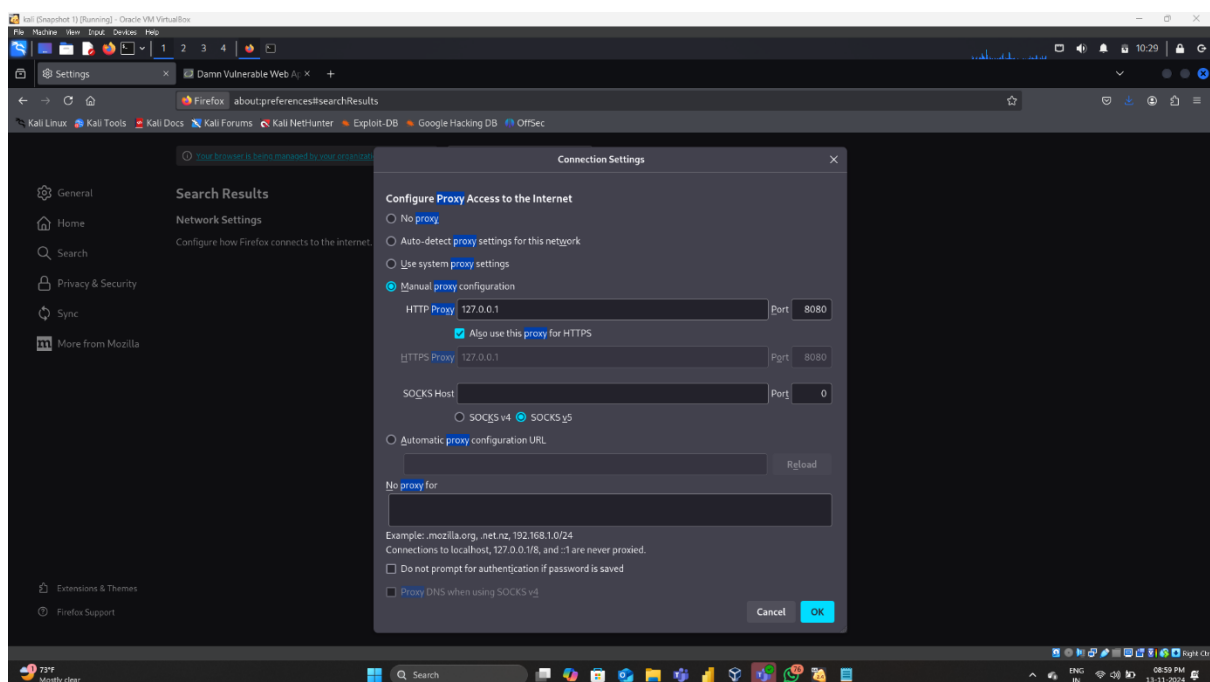
13. give any command (eg:ls) click on go



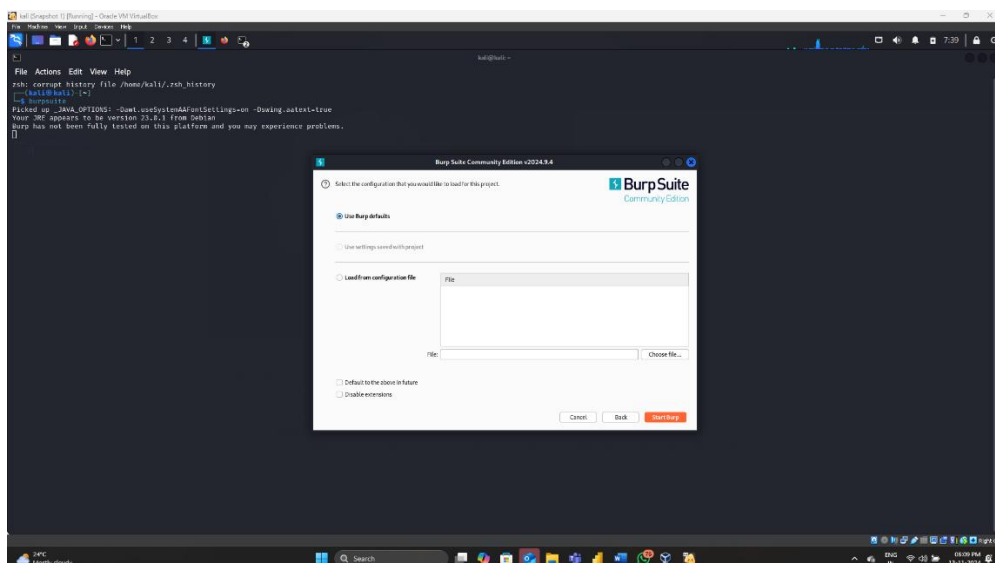
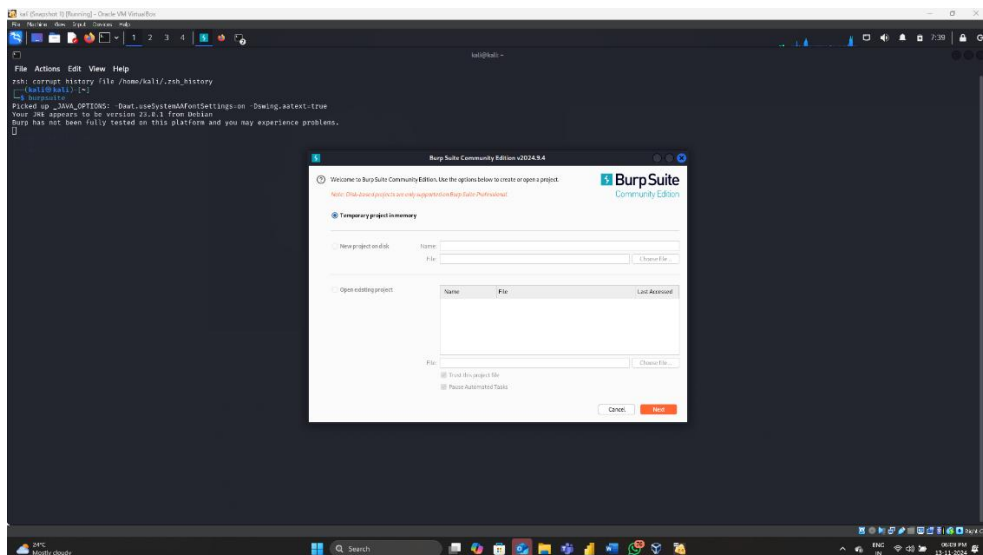
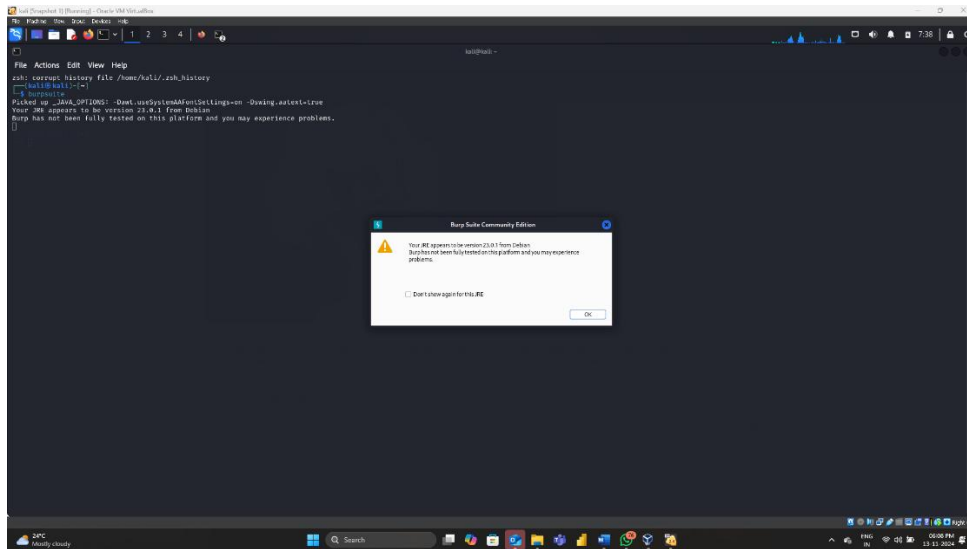
14. go to DVWA Security and set it in to as medium and click on submit

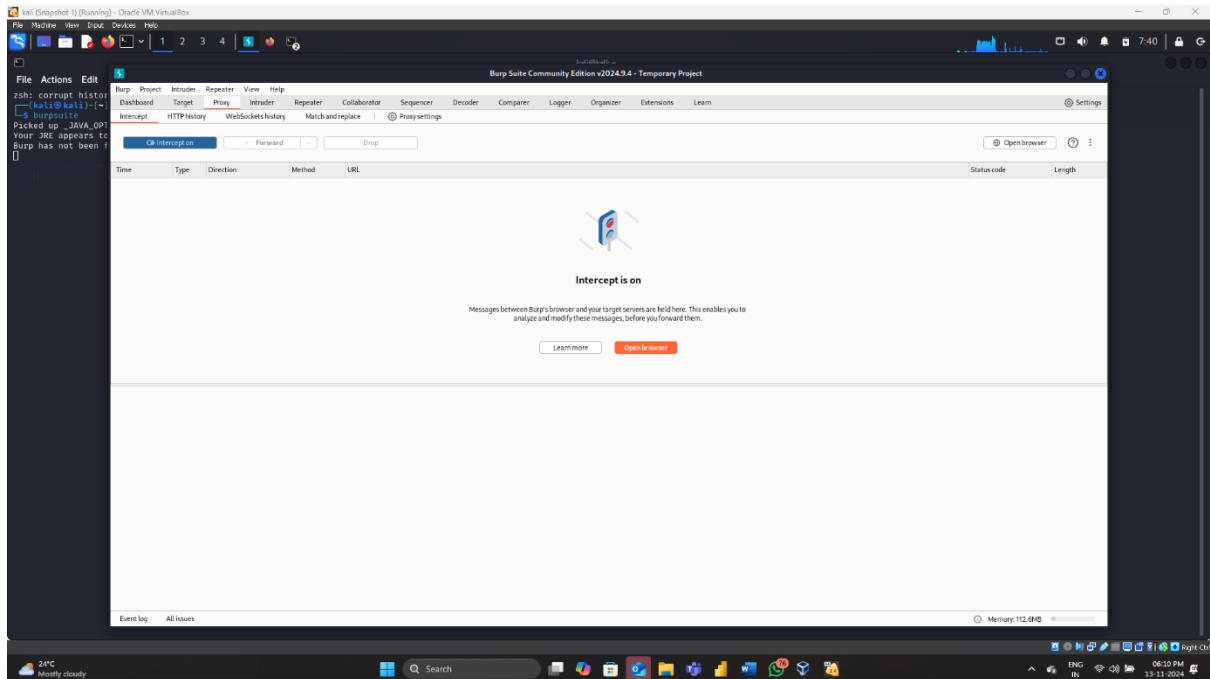


15. Set the proxy as Manual for accessing that burpsuite

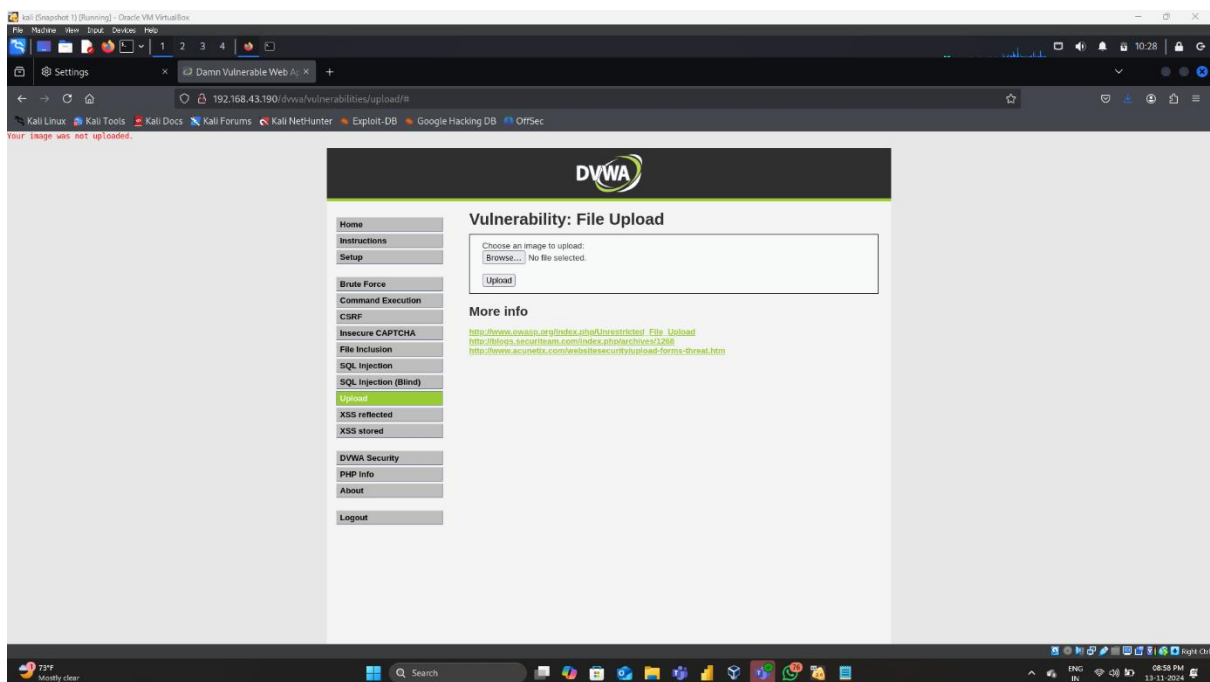


16. Start the burpsuite in the kali

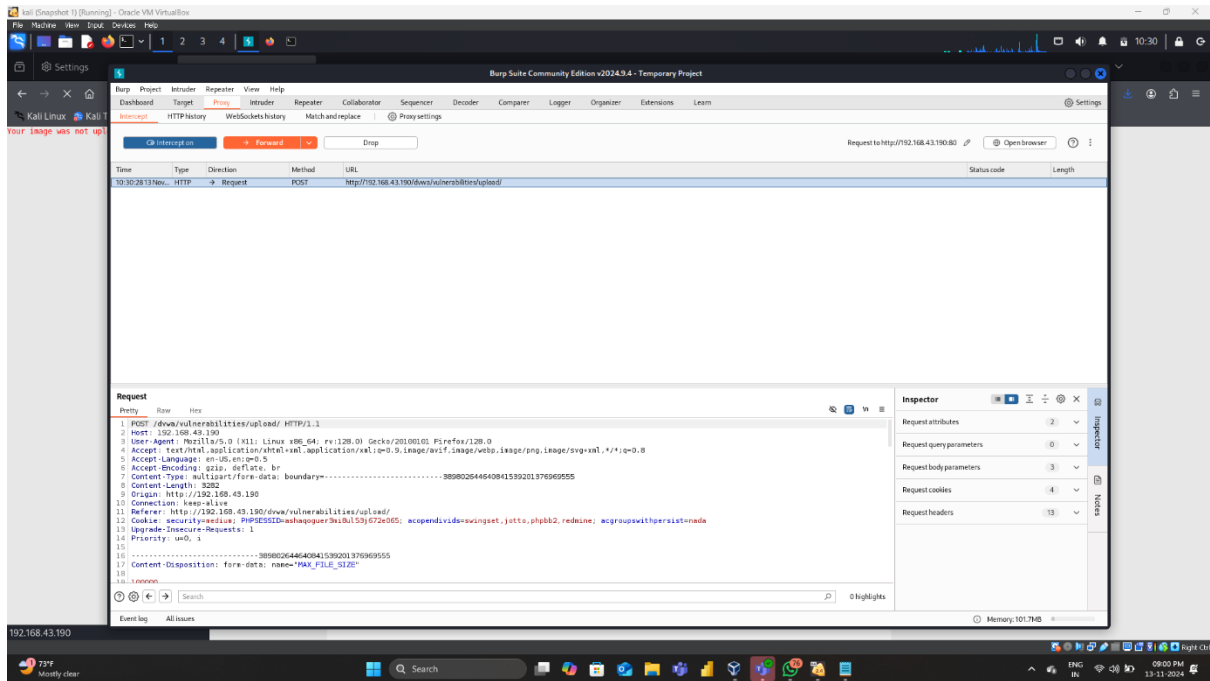




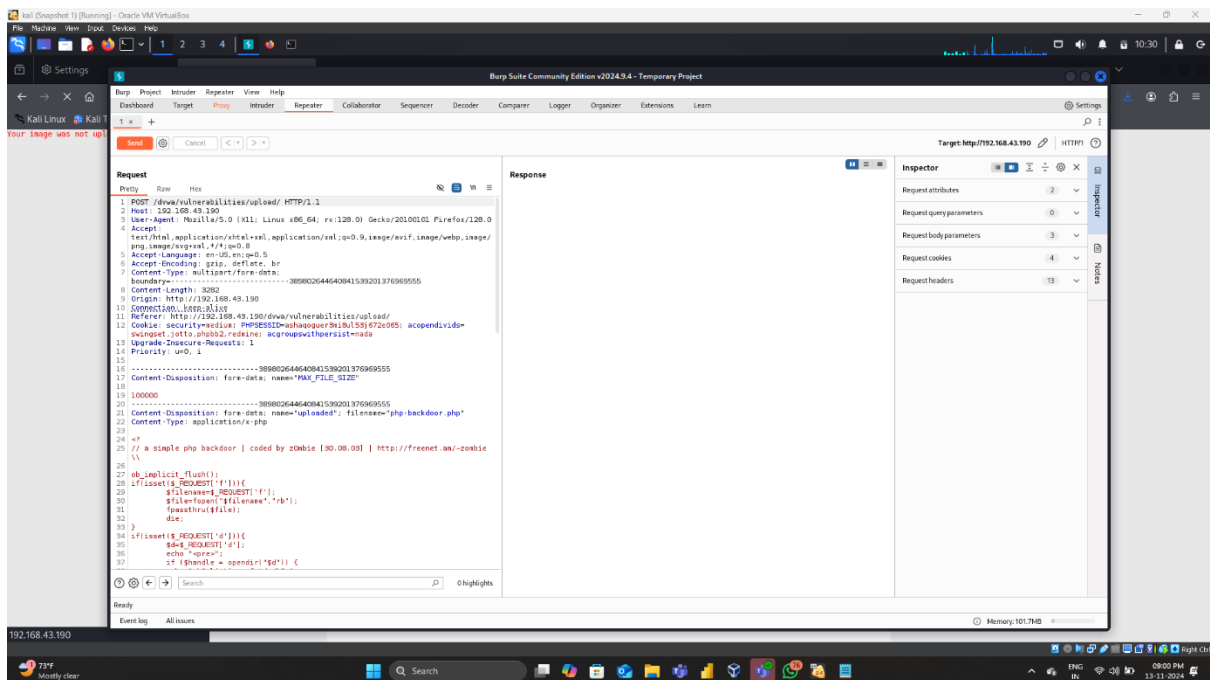
17. Turn on the Intercept and try to upload the file (in OWASP Machine firefox)



18. It automatically goes to here after clicking on upload button



19. Send it to Repeater



20. Do some Modification ant Content-type (Remove that line and just type image/jpeg)

